Universidade Presbiteriana Mackenzie

GOVERNANÇA E COMPLIANCE EM TI

Prof. Cleórbete Santos

Universidade Presbiteriana Mackenzie

Programa de Compliance

Universidade Presbiteriana Mackenzie

Pilares de um programa de Compliance

Pilares de um Programa de Compliance (Art. 42 do Decreto 8.420/2015):

- Suporte da Alta Administração (inciso I e IX);
- Gestão de Riscos (inciso V);
- Código de conduta, políticas e procedimentos (inciso II, III e VIII);
- Controles internos (incisos VI e VII);
- Treinamento e comunicação (inciso IV);
- Canais de denúncia (inciso X);
- Investigações internas (incisos XI e XII);
- Due Diligence (incisos XIII e XIV);
- Monitoramento e auditoria (inciso XV);

Universidade Presbiteriana Mackenzie

Pilares de um programa de Compliance

Suporte da Alta Administração (inciso I e IX):

- Convencer a Alta Administração;
- Definir o objetivo do programa de compliance;
- Conseguir o suporte e recursos para o programa;
- Engajar os envolvidos;

Exemplos de Suporte da Alta Administração

- O CEO grava um vídeo curto e direto para todos os colaboradores, afirmando que a ética é mais importante do que o lucro imediato;

- Durante um curso sobre prevenção à corrupção, os Diretores são os primeiros a comparecer e concluir o curso, demonstrando que ninguém está "acima" do aprendizado;

Universidade Presbiteriana Mackenzie

Pilares de um programa de Compliance

Gestão de Riscos (inciso V):

- Levantar normas aplicáveis;
- Conscientizar sobre o projeto;
- Identificar riscos;
- Criar matriz de risco;
- Realizar entrevistas com os envolvidos;
- Identificar controles existentes;
- Identificar riscos residuais;
- Criar relatório;

Exemplo de Gestão de Riscos

Em processos de compras, há risco de um colaborador aceitar gratificações para favorecer um fornecedor específico em detrimento da melhor proposta para a empresa.

Para tratar esse risco, deve-se implementar controles como segregação de funções (quem solicita a compra não é quem aprova o pagamento), exigência de no mínimo três cotações distintas para cada pedido e processo de due diligence para verificar a idoneidade do parceiro comercial antes da contratação.

Universidade Presbiteriana Mackenzie

Pilares de um programa de Compliance

Código de conduta, políticas e procedimentos (inciso II, III e VIII):

- Criar código de conduta;
- Criar políticas internas;
- Criar procedimentos internos;

Exemplo de código de conduta, políticas e procedimentos

O Código de conduta pode proibir conflitos de interesse, enquanto as políticas detalham regras específicas para temas sensíveis, como uma "Política de Brindes e Hospitalidade" que estipula um valor máximo permitido para presentes.

Complementando essa estrutura, os procedimentos podem definir o passo a passo operacional, determinando, por exemplo, que qualquer convite de fornecedor deve ser registrado em um formulário padrão e aprovado formalmente pelo gestor e pelo setor de Compliance antes de ser aceito.

Pilares de um programa de Compliance

Controles internos (incisos VI e VII):

- Escolher tipos de controles;
- Escolher formas de execução dos controles;

Exemplo de controle interno

Um controle interno pode ser a segregação de funções no departamento financeiro, escolhida estrategicamente por meio de uma matriz de riscos que identifique processos vulneráveis a fraudes, como o ciclo de contas a pagar.

Para executá-lo, devem ser configurados níveis de acesso distintos no sistema de gestão, garantindo que o funcionário responsável por cadastrar um novo fornecedor não possua a permissão para autorizar o pagamento a esse mesmo fornecedor.

E esse controle deve ser monitorado por meio de logs de auditoria periódicos, para confirmar se o controle está sendo respeitado, visando impedir que uma única pessoa tenha o controle total sobre uma transação financeira do início ao fim.

Pilares de um programa de Compliance

Capacitação (inciso IV):

1) Garantir a adesão dos líderes;
2) Criar plano de capacitação com base na organização;
3) Alocar recursos;
4) Escolher capacitações com base nos riscos prioritários;
5) Escolher temas e públicos;
6) Planejar e estabelecer metas;
    1) Formato EaD x presencial;
    2) Adesão obrigatória x voluntária;
    3) Capacitações genéricas x específicas;
7) Personalizar capacitações conforme os públicos;
8) Engajar os líderes;
9) Explanar sobre as vantagens das capacitações;
10) Monitorar as ações de capacitação;
11) Continuamente melhorar as ações de capacitação;
    1) Realizar benchmarking;

Universidade Presbiteriana Mackenzie

Pilares de um programa de Compliance

Comunicação (inciso IV):

- Criar plano de comunicação;
- Escolher formas de comunicação;
- Analisar vantagens e desvantagens das formas de comunicação;
- Definir local de acesso conforme a forma de comunicação;
- Usar linguagem conforme o público;
- Criar canal de dúvidas;
- Monitorar e avaliar;

Universidade Presbiteriana Mackenzie

Pilares de um programa de Compliance

Canais de denúncia (inciso X):

- Definir meios de denúncia;
- Definir o nome do canal de denúncia;
- Garantir requisitos de funcionamento;
- Definir forma de implantação;
- Definir forma de gerenciamento;
- Definir público-alvo;
- Definir infraestrutura do canal;
- Criar políticas e procedimentos do canal de denúncia;

Pilares de um programa de Compliance

Investigações internas (incisos XI e XII):

- Selecionar equipe para investigações;
- Criar plano de investigação;
- Identificar, obter a analisar evidências necessárias;
- Realizar entrevistas;
- Criar relatório;

Pilares de um programa de Compliance

Due Diligence (incisos XIII e XIV):

- Identificar terceiros que se relacionam com a organização;
- Identificar terceiros que requerem monitoração;
- Criar política e procedimentos de due diligence;
- Definir periodicidade de repetição do processo de due diligence;
- Identificar, obter a analisar informações necessárias;
- Realizar entrevistas;
- Criar relatório;

Pilares de um programa de Compliance

Monitoramento e auditoria (inciso XV):

Monitoramento:

- É procedimento interno com foco preventivo;
- Conduzido pela área de compliance;
- Objetiva a melhoria contínua;
- É executado continuamente;

Auditoria:

- Procedimento externo com foco reativo;
- Conduzida por parte externa (mesmo que pertença à organização);
- Objetiva identificar falhas e oportunidades;
- É executada de forma randômica, porém periódica;

Universidade Presbiteriana Mackenzie

Estratégia Organizacional e de TI

Universidade Presbiteriana Mackenzie

Estratégia Organizacional e de TI

A Estratégia Organizacional define aonde a empresa quer chegar (visão de futuro e diferenciação no mercado).

A Estratégia de TI estabelece como a tecnologia viabilizará o que for definido na Estratégia Organizacional de maneira alinhada.

Componente	Foco	Exemplo
Estratégia de Negócio	Vantagem competitiva e mercado.	Ser o banco digital mais seguro do país.
Estratégia de TI	Capacidade tecnológica e infraestrutura.	Implementar biometria facial e arquitetura em nuvem.
Alinhamento	Sincronia das estratégias.	A TI entrega a segurança que o marketing prometeu.

Universidade Presbiteriana Mackenzie

Governança Corporativa

Governança Corporativa

A Governança Corporativa é o sistema pelo qual as empresas são dirigidas, monitoradas e incentivadas, envolvendo o relacionamento entre sócios, conselho de administração, diretoria e órgãos de fiscalização.

Seu objetivo principal é garantir que a gestão da empresa esteja alinhada aos interesses dos proprietários e demais partes interessadas (stakeholders), mitigando o chamado "conflito de agência" — que ocorre quando os executivos tomam decisões em benefício próprio e não da organização.

Universidade Presbiteriana Mackenzie

Os 4 Pilares da Governança Corporativa

1) **Transparência (Transparency)**: Ir além da obrigação legal de exibir números; é o desejo de informar sobre fatores que guiam a ação gerencial e que conduzem à preservação de valor.
2) **Equidade (Fairness)**: Tratamento justo e igualitário de todos os sócios e partes interessadas, respeitando seus direitos e deveres.
3) **Prestação de Contas (Accountability)**: Os agentes de governança devem prestar contas de sua atuação de modo claro, assumindo integralmente as consequências de seus atos e omissões.
4) **Responsabilidade Corporativa (Responsibility)**: Zelar pela viabilidade econômico-financeira da organização, reduzindo externalidades negativas e cuidando da longevidade do negócio (aspectos ambientais, sociais e de governança - ESG).

Universidade Presbiteriana Mackenzie

Governança de TI

Governança de TI

A Governança de TI é uma extensão da Governança Corporativa que foca especificamente em garantir que os investimentos em tecnologia gerem valor ao negócio e que os riscos de TI sejam mitigados.

Enquanto a Gestão de TI foca em "entregar serviços", a Governança de TI foca em "fazer as coisas certas para o negócio".

Universidade Presbiteriana Mackenzie

Pilares da Governança de TI

- **Alinhamento Estratégico**: A TI está apoiando os objetivos da empresa?
- **Entrega de Valor**: Os projetos de TI trazem o retorno esperado (ROI)?
- **Gestão de Riscos**: Os dados estão seguros e os sistemas são resilientes?
- **Gestão de Recursos**: A infraestrutura e as pessoas estão sendo usadas de forma otimizada?
- **Mensuração de Desempenho**: Há métricas claras (KPIs) para saber se a TI está indo bem?

Universidade Presbiteriana Mackenzie

play.blooket.com

Universidade Presbiteriana
Mackenzie

Faculdade de
Computação e Informática